

ISO/IEC 27001:2022 ISMS Implementation

Project Summary — PrimeHealth Clinic & Diagnostics (Simulated)

Standard	ISO/IEC 27001:2022
Industry	Healthcare (Diagnostics, Telehealth, Clinical Services)
Jurisdiction	Australia
Scope	Whole-of-organisation ISMS — 7 departments, 40 sites
Deliverables	20 controlled documents covering Clauses 4–10

Executive Summary

This project delivers a full-lifecycle Information Security Management System (ISMS) designed to ISO/IEC 27001:2022 for a simulated Australian healthcare provider, **PrimeHealth Clinic & Diagnostics**. The organisation operates 40 branches nationwide, employs over 1,000 healthcare practitioners, and reports an annual turnover of AUD \$800M. Healthcare data sensitivity, multi-jurisdictional regulation, and reliance on cloud-based clinical platforms make information security a strategic priority.

The ISMS evidence pack covers the full Plan–Do–Check–Act cycle: context establishment, leadership commitment, risk assessment and treatment, operational controls, and ongoing performance evaluation. All 20 documents map directly to ISO 27001 clauses 4–10 and to Annex A controls.

Approach & Methodology

- **Context (Clause 4):** Established organisational profile, identified 18+ applicable standards and Australian regulations, and defined ISMS scope across 7 departments and 40 locations.
- **Leadership (Clause 5):** Drafted and obtained executive approval for the top-level Information Security Policy.
- **Planning (Clause 6):** Performed structured risk assessment using ISO 27005, produced a Risk Treatment Plan, and built a Statement of Applicability mapped to Annex A.
- **Support (Clause 7):** Defined competence requirements, RASCI matrix for ISMS roles, and a security awareness procedure.
- **Operation (Clause 8):** Documented business processes, information assets register, applied controls, and treatment outcomes.
- **Performance & Improvement (Clauses 9–10):** Established metrics, conducted internal audits, ran management review, tracked non-conformities, and produced BIA/BCP register.

Regulatory & Standards Landscape

Beyond ISO/IEC 27001, the ISMS aligns with healthcare- and Australia-specific obligations including: **Privacy Act 1988, HRIP Act 2002, ACSC Essential Eight, NPAAC, NSQHS Standards, NHMRC Guidelines, Therapeutic Goods Act 1989, Health Practitioner Regulation National Law, ISO/IEC 27002, ISO 27005, ISO/IEC 17025, ISO/IEC 15189:2023, and COBIT.**

Skills Demonstrated

- Governance, Risk & Compliance (GRC) programme design
- ISO 27005 risk management methodology — identification, analysis, evaluation, treatment

- Annex A control selection and Statement of Applicability authoring
- Policy and procedure drafting at executive level
- Internal audit planning, execution, and reporting
- Business Impact Analysis (BIA) and Business Continuity Planning (BCP)
- Regulatory mapping across multiple Australian healthcare regimes
- Stakeholder engagement and management review facilitation

PrimeHealth Clinic & Diagnostics is a fictional company created for academic and portfolio purposes only. This document does not represent an actual certified ISMS implementation.